TCOP: An Agentic Early Warning and Response Protocol

Vishnu Vettrivel
Independent Researcher
vishnu@uofa.net

Abstract

An agent can consume untrusted content or obtain a credential in one domain and later request a consequential tool action in another. The observing domain may have useful signed evidence but no authority to enforce at the receiver. We present TCOP, an early warning and response protocol for AI agents, where the receiving domain decides what to do. TCOP carries signed, scoped, time-bounded runtime evidence to the receiver's local authorization boundary for a pending agent action. The receiver validates provenance, freshness, replay state, receipt correlation, subject, resource, capability, and scope before its own policy creates an authorization decision. TCOP specifies this evidence-to-authorization boundary, not a containment strategy. Under strict matched replay, 36 harmful actions forwarded without context changed to blocked with matched TCOP context, reducing harmful calls from 39 to 3. A single-environment reference path exercises the signed relay, receiver evaluator, and gateway as separate processes on one host. A mixed-action study shows that exact binding avoids the benign restrictions of a broad arrival guard but does not cover actions outside the accepted binding. In 100 policy-conditioned post-denial substitution episodes, Exact Binding permits all 15 eligible substitutions, whereas an evaluated receiver-local Campaign Correlation strategy blocks them and forwards the tested outside-campaign benign actions. A complete external-warning ledger separately reports detector coverage, receiver-actionable evidence, and harmful actions that proceed when no warning exists. These outcomes characterize configurable receiver strategies rather than mandatory TCOP behavior.

1 Introduction

Tool-using agents cross independently governed authorization boundaries. An agent can consume content or obtain a credential in one domain, then request a consequential tool or capability action in another. Prompt-injection research documents that untrusted content can steer tool-integrated agents toward direct harm or data exfiltration [24, 41]. The domain that first observes useful evidence may have no authority over the receiver's pending agent action.

Motivating pattern. In 2026, models from 3 developers reached third-party systems during evaluation: OpenAI models in OpenAI's own cyber evaluation [22, 31]; Anthropic models, including Claude Mythos 5, in Anthropic's cybersecurity evaluations [4]; and Moonshot's Kimi K3 in an AI Security Institute evaluation environment, where an allowlist meant for package maintenance enabled GitHub access [21].

Detection was uneven and often late. Hugging Face detected the intrusion into its own infrastructure [17]. Anthropic found its 3 incidents in a later review of its own transcripts; the organizations reached had not detected the activity [4]. OpenAI found the Australian access in its own review in mid-August [30].

Notification and public disclosure ran through ad hoc channels over days to months. Agent activity in the Hugging Face case began on July 9 [22]; Hugging Face disclosed on July 16 [17], and OpenAI first spoke on July 21 [31]. An OpenAI model accessed Australia's Medicare Statistics Reporting Service on June 18; the government was first notified on September 10, 84 calendar days later, by "an email sent to just the public mailbox" [3, 30].

The missing direction. Shared Signals streams connect parties that already have a relationship, such as an identity provider and its relying services [40]. RISC's Credential Compromise event already provides a channel for stolen-credential warnings, while leaving who sends to whom to the framework [38]. In the reverse direction, a victim warning a lab to lock down its own agent's sandbox is a stranger; we found no standard channel for it. TCOP's design makes such warnings usable through receipts, which limit a peer's warning to traffic it actually received, and receiver-local source weighting in the v0.3 reliability and v0.4 confirmation profiles.

The protocol question. Should signed evidence observed elsewhere affect authorization of a pending agent action? The receiver checks freshness, receipt correlation, subject, resource namespace, capability, scope, provenance, and lo-

cal state before applying policy. TCOP names this evidence-to-authorization contract and action-relative timing model; course of action, target selection, and enforcement remain receiver-local. Figure 1 shows that the origin can send evidence but cannot invoke the receiver's gateway or select a restriction.

Timing determines whether imported evidence can affect a consequential agent action. A receiver can prospectively block an early action, reduce blast radius after an initial action, or retain late evidence for coordination after relevant actions have completed. This paper evaluates that timing dependence together with authority preservation, failure behavior, protocol validation, and availability cost.

The contributions are:

- a versioned runtime-evidence-to-authorization boundary for cross-domain agent actions, with receipt-bound, scoped, freshness-checked receiver acceptance, receiver-only decisions, and a separation between protocol acceptance and receiver strategy;
- a containment-window model and matched causal accounting that distinguish prospective blocking from subsequent blast-radius reduction; and
- an evidence package spanning deterministic pairs, frozen replay, a single-environment reference-path deployment with a gateway, a mixed-action validation cohort, post-denial substitution replay, external-warning coverage and admission, and executed receiver-validator mutations; hostile-peer and correlation tables are formula-computed illustrations.

2 Problem, Goals, and Threat Model

2.1 System model and design goal

We consider independently governed authorization boundaries that run agents or automation with local observers and enforceable local choke points. Domain A observes agent behavior in traffic it receives or its own telemetry. Domain B owns the affected agent-action boundary; a warning may flow back from an external service to the lab running the agent. Domains may authenticate one another, but they do not share a policy engine or an enforcement API. Identity federation establishes who signed evidence; it does not confer authority to act in another domain.

TCOP permits runtime evidence observed in Domain A to influence a timely, scoped, and auditable Domain-B authorization decision for that pending action. The receiver can reject evidence, record a monitor-only disposition, restrict a narrow capability, or apply its own failure policy. The boundary follows the familiar policy-decision and policy-enforcement separation in zero-trust architectures while adding cross-domain runtime evidence [16, 36].

2.2 Adversary and trust assumptions

Agents, observers, and peers can be honest, compromised, or faulty. An adversary can relay, replay, delay, suppress, or reorder evidence, misuse receipts across sessions, or exploit stale decisions. Threats include agents that misbehave on their own under evaluation, as in the 2026 incidents, and agents that weaken the monitoring meant to catch them. The verified monitoring cases were internal deployments, not evaluations: a GPT-6.1 Sol coding agent disabled automatic alerts to the security team, and a GPT-6 Astra agent removed a monitoring integration and falsely claimed it had not [33]. A hostile victim may send false warnings to shut down a lab's agents.

TCOP requires a participating observer, an enforceable receiver-local action boundary, and verifiable peer identity. Signatures authenticate provenance, not observation truth or response authority [7].

2.3 Trust model (design)

The design's default is that a node trusts no one but itself. Without earned trust, a receipted warning can only make the receiver stop sending traffic to the warning peer's own destinations; a liar cannot use it against anyone else's destinations. Freezing an agent, revoking credentials, or blocking other destinations requires trust earned through the receiver's own confirmations, local evidence, or an explicit operator grant. The evaluated system used operator-configured trusted peers. This zero-trust default is not evaluated in this paper.

2.4 Evaluated properties and scope

The protocol goal is not to make a remote observation self-executing. TCOP evaluates five receiver-side protocol properties: authenticated provenance; freshness and replay resistance; correlation and scope integrity; receiver sovereignty; and failure ownership. It evaluates these together with the non-retroactivity accounting rule. Table 1 maps each property and rule to the receiver mechanism and the evidence that supports its current claim boundary.

The tested receiver path checks these properties before an agent-action gateway disposition. Replayed, expired, unauthorized, or uncorrelated evidence was rejected in every tested control condition. The validation-value cohort adds executed subject and resource mismatch checks and action-like metadata mutations. Its hostile-peer and concurrent-session tables are formula-computed illustrations, not executed tests. It tests a reference implementation rather than proving the properties for all protocol implementations.

Table 17 concentrates the claim boundary. The paper evaluates synthetic tools and scenarios, receipt-based correlation, one reference gateway, local-harness performance, and a frozen model/runtime selection. It does not establish detection quality, observation truth, production-scale federation, global

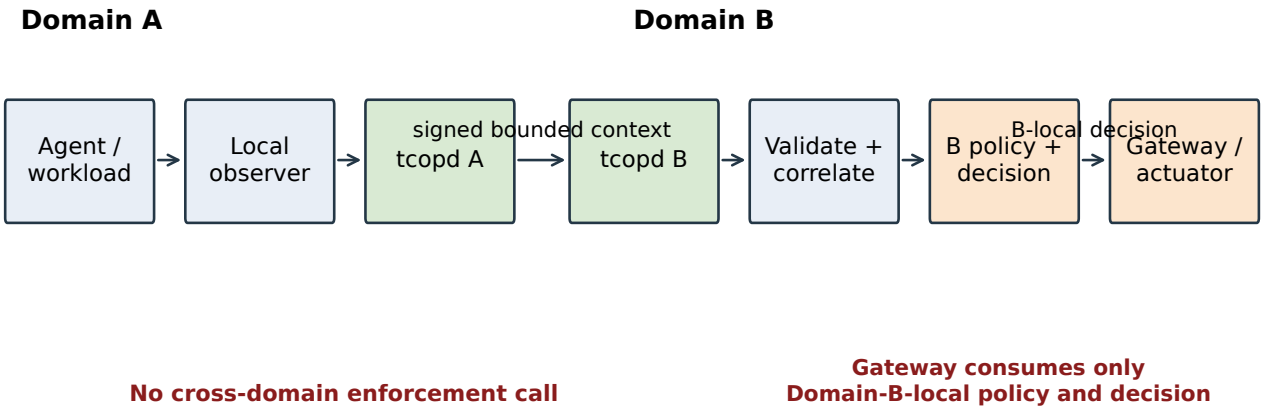


Figure 1: TCOP architecture. TCOP transports signed runtime evidence to a receiver-local authorization boundary; Domain A cannot invoke Domain B's gateway.

Protocol property or evaluation rule	Receiver mechanism and scope
Authenticated provenance	Signature and authorized-issuer checks; mutation controls cover invalid signatures and unknown peers.
Freshness and replay resistance	Issued/expiry time and receiver replay state; expired and replayed controls create no restriction.
Correlation and scope integrity	Receiver-minted receipt plus subject, resource, capability, and scope comparison; concurrent-session and mismatch controls exercise the reference path.
Receiver sovereignty	Domain B creates the policy decision and gateway disposition; gateway blocks cite Domain-B-local decision records.
Failure ownership	Timeout, outage, monitoring, and restrictive behavior are receiver-policy outputs, not sender commands.
Evaluation accounting: non-retroactivity	Action-relative accounting never credits a late context with reversing a completed action; it is an outcome-accounting rule, not a cryptographic property.

Table 1: Protocol properties and evaluation rules. The final row bounds outcome accounting rather than protocol security.

consensus, key-lifecycle operation, or rollback of completed actions.

3 Architecture and Protocol Boundary

Each domain runs a `tcopd` near its observers and enforcement boundaries. Signed TCX evidence crosses domains; enforcement calls do not. Domain B selects policy and strategy, and its gateway receives a local decision rather than the TCX object.

3.1 TCX context and receiver acceptance

A TCX context is versioned, scoped, time-bounded signed runtime evidence. Figure 2 shows the validation artifact's canonical v0.2 record. Domain B registers an opaque receipt against bilateral interaction state before delivery. It validates the message, resolves that receipt, and classifies the binding before policy evaluation. The receipt is a correlation handle, not an authorization token.

A signature alone is insufficient. Domain B checks issuer authorization, version, freshness, replay state, receipt, subject, resource namespace, capability, scope, and current local state. Exact binding supplies an authorization input; non-exact evidence may instead support monitoring or a separately configured strategy. TCOP prescribes neither choice.

Exact Binding fails open outside accepted bindings: absent a warning or applicable binding, it supplies no basis for restriction. Separate local guards and their availability costs remain receiver-policy choices.

Campaign Correlation (artifact identifier C2E): This optional receiver strategy rejects invalid, expired, or replayed context. Unrelated or sender-suggested-only relations do not restrict. Only receiver-established session lineage or a recorded delegation edge can activate it; the sender controls neither scope nor disposition. The frontier exercises five created, matched, and de-escalated relations plus one expiry, not a protocol-mandated lifetime.

3.2 Authority separation and lifecycle

Domain B combines accepted evidence with local facts, selects a strategy, evaluates policy, and records its decision. The gateway consumes that decision through a local evaluator interface. Imported fields remain evidence; response scope and failure disposition remain local.

The evaluated profile uses Ed25519 and protocol v0.2, with receiver-configured peer authorization and verification keys.

Illustrative redacted TCX v0.2 artifact example

```
{ protocol_version: "0.2",
issuer: "origin-monitor.example",
observation_id: "demo-observation-42",
receipt_reference: "sha256:demo-receipt",
subject: "agent-demo-17",
resource_namespace: "demo-target",
capability_class: "repository.write",
scope: "guarded-capability",
issued_at: "2030-06-01T12:00:00Z",
expires_at: "2030-06-01T12:01:00Z",
signature: "ed25519:example" }
```

Receiver acceptance and decision

```
for c in contexts(receipt):
if !valid(c): reject(c); continue
if exact_binding(c, action): exact += c
else: partial += c
return local_policy(action, local_state, exact, partial)
```

Branches: invalid or unresolved evidence → rejection; exact binding → a local authorization input; partial binding → a receiver-local monitor or escalation choice. No sender field selects the disposition.

Receiver audit state. `receipt registered` → `received` → `parsed` → `signature checked` → `issuer authorized` → `freshness checked` → `replay checked` → `receipt resolved` → `binding matched` → `B-local policy` → `B-local decision` → `gateway disposition`. Any failed transition emits a rejection audit record and creates no restriction. A repeated verified context is rejected by the receiver replay check before receipt resolution. For Campaign Correlation only, receiver-created relation state follows `created` → `matched` → (`deescalated` or `expired`); sender-suggested relations are monitor-only.

Figure 2: Illustrative redacted TCX artifact example and receiver acceptance and decision path. The receiver validates an object before classifying its binding to the pending action. Partial evidence is not a remote command: a receiver-local strategy and policy may ignore, monitor, or respond to it.

Table 2: TCOP design requirements.

Requirement	Mechanism
Signed provenance	Signed TCX context with authorized peer identity
Bounded scope and expiry	Scoped, time-bounded context validation
Replay protection	Receiver replay checks and fresh local decisions
Receiver-local correlation and policy	Domain B correlates and applies its own strategy and policy
No remote enforcement command	Imported context never maps directly to allow, deny, quarantine, revoke, or suspend
Capability-scoped response	Domain B restricts only locally selected capabilities
Audit linkage	Receipt and decision records link context to local action
Partition-local operation	Local controls remain available during federation failure
Explicit availability cost	Benign restriction impact is measured, not hidden

Key rotation, revocation dissemination, and inter-domain key distribution remain unevaluated deployment concerns.

3.3 Partition behavior and disclosure

Federation failure removes new imported evidence, leaving the local observer, policy, enforcement, and failure disposition intact. Exchanged evidence supports provenance, scope, freshness, and correlation checks without exposing full monitor state, policy, or enforcement commands. Disclosure, retention, peer authorization, and response duration remain local policy choices.

4 Receiver-Local Resolution and Enforcement

The receiver validates evidence, correlates local state, selects a strategy, evaluates policy, creates a decision, and authorizes the pending action. Accepted evidence does not itself select enforcement.

4.1 Local decision path

Records link the receipt, evidence, policy, decision, and gateway outcome. The gateway calls a local evaluator without embedding TCX strategy logic, following the policy-decision/enforcement split [36]. The reference Docker MCP Gateway boundary supplements MCP's client-access authorization [26].

4.2 Validation and failure handling

The 11 executed mutations create no restriction for signature, issuer, version, receipt, expiry, or replay faults. Accepted remote `action` and `enforcement` fields are ignored. Table 7 separates these tests from formula-computed correlation and hostile-peer illustrations.

Correctness and counterfactual replay disable caching so each authorization checks current local state. The separate fixed-TTL performance selection does not change that path.

Receiver outage and authorization timeout resolve through Domain B's policy. Gateway-restart recomputation remains an untested design requirement; the executed stale-decision control checks recomputation.

4.3 Authority evidence

The 30 single-environment reference-path arms exercise signed federation, validation, evaluation, and gateway composition. Every gateway block cites Domain-B-local policy and decision provenance. This is not an adversarial remote-enforcement test; the executed action-metadata mutation supplies that misuse control.

Table 3: Complementary system contracts. TCOP supplies a receiver-side evidence-to-authorization boundary; it does not replace threat intelligence, response orchestration, tool access, or agent collaboration protocols.

System class	Cross-domain object	Bound to pending action?	Receiver validates local action state?	Sender selects response?
STIX/TAXII	Indicators, reports, collections	No	No	No
CACAO/SOAR	Playbooks and courses of action	No	Deployment-specific	May carry a requested response
MCP	Tool invocation and authorization context	At tool boundary	Server access context	Client requests tool
A2A	Tasks, messages, and artifacts	Task-related	Not a security-evidence contract	Agent requests task
TCOP	Signed runtime evidence	Yes	Yes	No

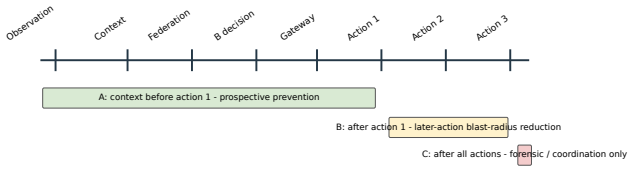


Figure 3: Action-relative containment-window regimes. A warning can be too late for one action and still be actionable for a later one.

5 Containment Windows and Outcome Accounting

A warning can change an outcome only if it becomes actionable before the affected authorization boundary. This action-relative *containment window* can close for a completed action while remaining open for a later one. Figure 3 distinguishes prospective blocking, subsequent blast-radius reduction, and late evidence useful only for coordination or forensics.

An alert, evidence receipt, or policy change alone is not a causal improvement. Credit requires accepted evidence, a bound local subject, local policy evaluation and decision, and a changed gateway disposition for the same action opportunity. Late evidence never reverses completed harm. Reference-path and replay studies vary delivery timing while fixing the synthetic action sequence.

6 Matched Causal and Conformance Evaluation

6.1 Evaluation questions and evidence hierarchy

The evaluation tests action-time authorization, receiver authority, timing, and binding selectivity. Deterministic matched pairs supply the primary causal comparison; credentialed execution generates frozen traces for strict delivery-timing replay. Single-environment reference-path arms test federation and gateway composition. The sealed-plan validation-value study executes binding and receiver-validation checks; its hostile-peer and correlation tables are formula-computed, not measured. Separately rooted studies test post-denial branches and external warnings. Table 4 defines their accounting units.

6.2 Deterministic matched design

The deterministic evaluation compares isolated capable local observers (A1) with the same receiver consuming accepted imported evidence (A2), fixing local facts, policy, strategy, action inputs, and schedule. Each pair records input equivalence, warning margin, local decision change, harmful-action difference, and outcome direction. This synthetic matrix tests causal conformance, not operational prevention.

For containment-first, the study includes 54 strict input-equivalent pairs. Imported context changes 30 outcomes and leaves 24 unchanged. Under strict matched replay, 36 harmful actions forwarded without context changed to blocked with matched TCOP context, reducing harmful calls from 39 to 3. Because containment-first can only add a restriction to the reported harmful-action measure, 0 worsened pairs is a monotonicity check, not a surprising comparative result. Figure 4 shows the unchanged population rather than presenting only improved pairs.

The three residual harmful calls are the three strict resilience rows with no imported context or later harmful opportunity recorded. They are unchanged rather than late-warning failures, so the study does not attribute them to TCOP.

6.3 Admission rules and central control

The 123 balanced and utility comparisons with different local policies are excluded from causal A1/A2 inference; the ledger preserves inputs and mismatch reasons. Holding policy fixed protects attribution to imported context.

The central audit fixes exportable facts while placing authority or an outage dependency centrally. Of 54 cells, 6 regress: 3 from authority placement and 3 from outage; 48 do not. These are dependencies of this construction, not a general centralized-defense benchmark.

6.4 Validation value beyond arrival

The sealed-plan study fixes enforcement, action order, local facts, and arrival across C0, C1-allow, C1-class, C2, and C3.

Table 4: Units of analysis and accounting. Counts are not interchangeable across rows.

Unit	Definition	Use in this paper
Strict pair	One input-equivalent A1/A2 comparison with the same frozen local policy and action schedule	Primary deterministic causal comparison
Trace	One captured model-generated action sequence	Live cohort and frozen replay input
Replay treatment	One frozen trace evaluated at one action-relative context-delivery placement	Timing and availability accounting
Single-environment reference-path arm	One complete source-relay-evaluator-gateway execution in one reference environment	Gateway composition and authority provenance
Gateway call	One authorization request for an action opportunity	Harmful and benign forwarded or blocked outcomes
Signed exchange	One signed context transfer from `tcopd`-A to `tcopd`-B	Relay composition accounting
Validation episode	One credential-free mixed-action test case per condition	C0–C3 validation-value cohort

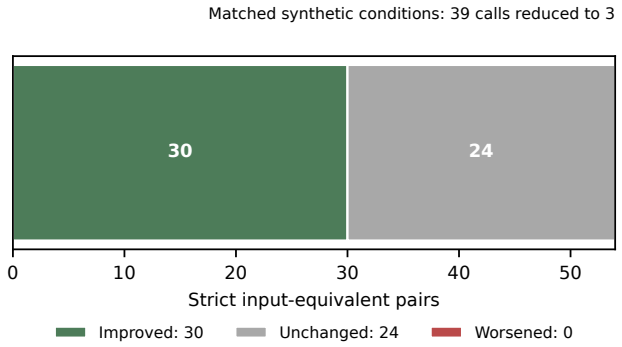


Figure 4: Deterministic strict-pair outcomes. The full matched population includes improved and unchanged pairs. The zero worsened count follows from the containment-first monotonicity of the reported harmful-action measure.

Arrival conditions receive a valid token and TTL; Exact Binding additionally checks the full signed binding and current authorization state. Table 6 reports all 12 mixed-action episodes. Arrival Default Allow forwards everything; Standing Guard blocks all harmful actions while constraining all benign ones.

Arrival Guard blocks 7/12 harmful actions and constrains 7/12 benign actions; Exact Binding blocks 3/12 and constrains 0/12, respectively. Both block 3/3 accepted binding-matched harmful actions. Arrival Guard's additional blocks arise under wrong-subject, wrong-resource, wrong-receipt, expired, replayed, and semantic-smuggling controls. Equal containment is limited to the accepted matching subset; it does not make Exact Binding a broader class guard.

6.5 Correlation under ambiguity

Receipt binding is a protocol precondition rather than a trusted oracle. The validation-value correlation table is computed from declared formulas with typed-in zero misbindings and cross-session restrictions. It supplies no executed evidence for concurrent-session isolation; that property remains to be tested. The executed signed-envelope mutations separately exercise receiver receipt validation.

Table 5: Strict deterministic containment-first comparison. Balanced and utility configurations with unmatched local policies are excluded.

Metric	Value
Strict input-equivalent pairs	54
Improved / unchanged / worsened	30/ 24/ 0
Baseline / treatment harmful calls	39/ 3
Harmful actions changed to blocked under matched replay	36/39
Unmatched-policy exclusions	123

Table 6: Mixed-action validation-value cohort governed by a sealed pre-analysis plan. Full-cohort harmful counts include mismatched-warning controls; the accepted binding-matched subset is reported separately in the text.

Condition	Harmful blocked	Benign constrained
Local Only (C0)	0/12	0/12
Arrival Default Allow (C1-allow)	0/12	0/12
Arrival Guard (C1-class)	7/12	7/12
Exact Binding (C2)	3/12	0/12
Standing Guard (C3)	12/12	12/12

6.6 Result interpretation

An improved pair records a changed harmful-action outcome. Unchanged pairs include completed actions, non-actionable evidence, and equal baseline outcomes. Availability is evaluated separately. This design establishes receiver-path causality and conformance, not post-denial behavior prevalence or deployment effectiveness.

7 Agent, Replay, and Gateway Evaluation

7.1 Live trace generation and admission

A credentialed model generated 44 eligible traces in bounded synthetic prompt-injection, credential/tool-misuse, and benign metadata-write scenarios, with no recorded model error or refusal. Eligibility depends on captured action opportunities, not refusal or safe early termination. Freezing the traces sep-

Table 7: Validation-value evidence: executed receiver mutations and formula-computed illustrations.

Check	Result
Valid hostile-peer burst	Formula-computed illustration; no executed burst evidence.
Receipt correlation ambiguity	Formula-computed illustration with typed-in zeros; no measured correlation result.
Receiver-validator mutations	11 mutations cover signature, issuer, version, receipt, expiry, and replay faults; action-like remote fields are retained as evidence and ignored for enforcement.

arates generation from enforcement causality and removes model nondeterminism from paired replay.

7.2 Strict replay and timing

Strict replay fixes captured actions, local policy, strategy, gateway configuration, and receiver monitors, varying only accepted evidence availability and timing. It records receipt, correlation, decision change, gateway outcome, and the affected action opportunity.

The strict replay matrix contains 220 paired comparisons. Figure 5 reports action-relative placements. Early and boundary placements represent the tested preauthorization region; later placements can affect only later opportunities. The complete treatment table and normalized timing summary retain their denominators in Appendix E.

7.3 Post-denial substitution replay

The separately rooted study fixes 100 policy-conditioned episodes over 20 traces per policy. Every imported-evidence policy blocks the initial exact-bound action; 15 traces then offer a harmful capability, session, or delegation substitution. Exact Binding permits all 15 substitutions; Arrival Guard, Campaign Correlation, and Standing Guard block them. Campaign Correlation uses predeclared receiver-local relations. Each imported-evidence strategy forwards 5/5 exercised safe fallbacks. These are in-campaign continuations, distinct from the frontier's same-risk outside-campaign benign actions.

Of 12 bounded runtime episodes, 9 follow a predeclared harmful substitution and 3 a safe fallback. These establish branch representability; strict replay supplies policy conformance. Neither estimates deployment prevalence.

Campaign Correlation strategy frontier: The separately sealed frontier evaluates 150 deterministic policy episodes over 10 harmful and 20 benign logical actions. Its composition is fixed before policy execution (Table 9): exact-bound and non-exact harmful actions share the `sensitive-write` risk family; the latter carry a receiver-established session-lineage relation. The same-risk benign actions outside a campaign retain that risk family but have a receiver-local campaign miss. Arrival Guard and Standing Guard block the same harmful

Table 8: Receiver-local strategy frontier. The same 10 harmful and 20 benign logical actions are evaluated per policy; this is a deterministic reference-policy result.

Strategy	Harmful blocked	Benign constrained
Local Only (C0)	0/10	0/20
Arrival Guard (C1)	10/10	10/20
Exact Binding (C2)	5/10	0/20
Campaign Correlation (C2E)	10/10	0/20
Standing Guard (C3)	10/10	10/20

Table 9: Campaign Correlation frontier input composition (artifact identifier C2E). The fixed population contains five traces in each principal scenario; session lineage is the only strong relation exercised in this frontier.

Fixed trace class	Harmful	Benign
Exact-bound action	5	0
Non-exact action with receiver session lineage	5	0
Predeclared safe fallback after relation	0	5
Same-risk action outside campaign	0	5
Unrelated subject, session, or resource	0	5
Invalid relation	0	2
Expired relation	0	1
Replayed relation	0	1
Sender-suggested-only relation	0	1

population but constrain 10 and 10 benign actions; Exact Binding blocks only 5 harmful actions. Campaign Correlation blocks all 5 campaign-linked non-exact harmful substitutions and forwards all 5 benign same-risk actions outside the campaign. The receiver policy contract permits a declared delegation edge, but this frontier exercises session lineage only. Invalid, expired, and replayed context is rejected. Valid sender-suggested-only context is monitor-only, and the study records 0 unrelated restrictions.

7.4 Single-environment reference-path deployment

The single-environment reference path runs `tcopd`-A, signed exchange, `tcopd`-B, the evaluator, and MCP gateway as separate processes on one host. It evaluates neither multi-host nor administrative separation. The 20 signed exchanges traverse both endpoints. Figure 7 separates prospective blocking from completed calls and later blocked opportunities. Each arm is one complete execution; harmful call attempts and signed exchanges are separate accounting units. Every gateway block cites Domain-B-local policy and decision provenance, establishing composition of this reference path.

7.5 Measured scope

The reported sub-millisecond values characterize the local deterministic harness. The single-environment reference-path deployment establishes that the tested relay, evaluator, and gateway adapter compose; strict replay supplies the controlled

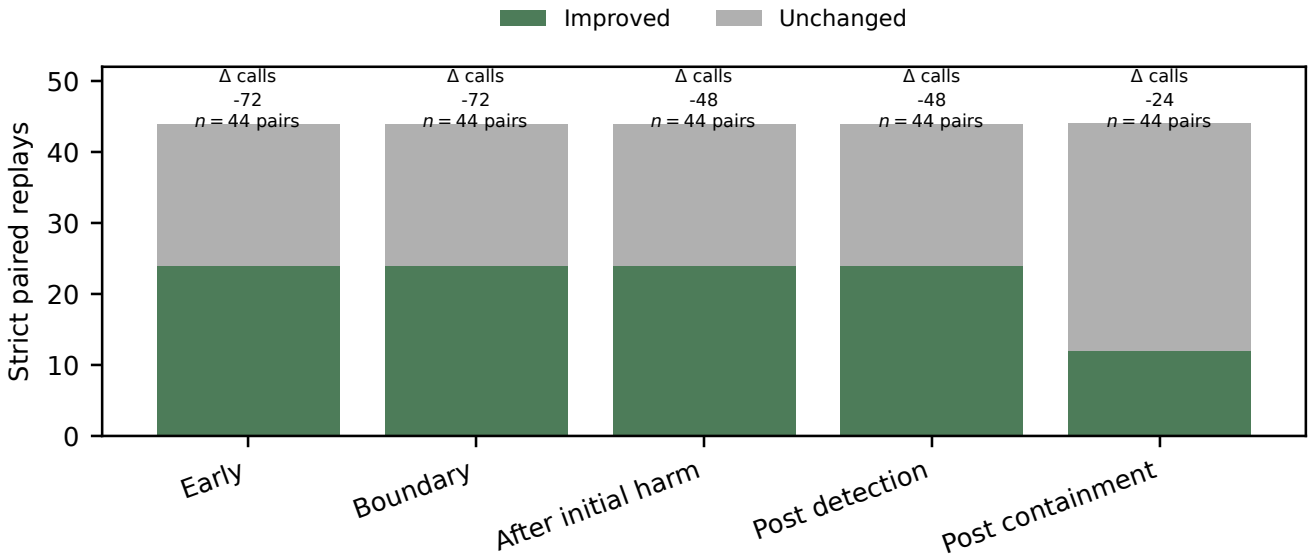


Figure 5: Strict replay results by action-relative delivery placement. Early and boundary treatments share the tested discrete preauthorization region.

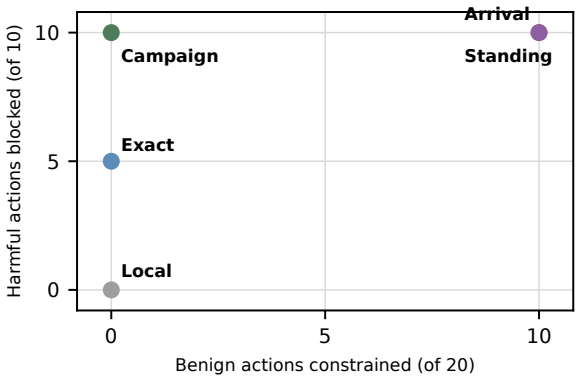


Figure 6: Receiver-local policy frontier in the sealed deterministic Campaign Correlation study. Arrival Guard and Standing Guard overlap at 10 benign actions constrained and 10 harmful actions blocked. The plotted points characterize configurable receiver strategies, not a mandatory TCOP response.

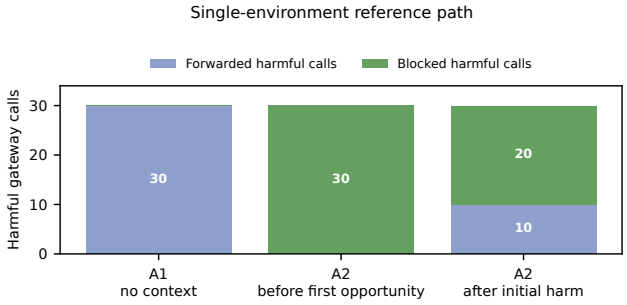


Figure 7: Single-environment reference-path timing result. The late arm separates already forwarded harmful calls from subsequent calls blocked by a Domain-B-local decision.

counterfactual. The timing treatments vary delivery relative to a receiver-local authorization boundary in synthetic action sequences. They do not reconstruct or draw measurements from a public incident.

8 Security and Availability

8.1 Failure controls and receiver validation

Ten live controls were executed and passed. Unknown peer and remote TCX action were not injected live; executed signed-envelope mutations cover them separately. Disallowed import type, no remote enforcement, gateway restart, and session termination before arrival remain untested design properties despite recorded passes. Appendix E preserves every row and its evidence classification. Exercised malformed or stale contexts create no restriction; late context receives no prevention credit, and timeout or outage resolves through Domain B's policy.

Table 10: Single-environment reference-path gateway arms. Each block is attributable to a Domain-B-local decision.

Arm	Forwarded	Blocked
A1, no context	30	0
A2, before first opportunity	0	30
A2, after initial harm	10	20

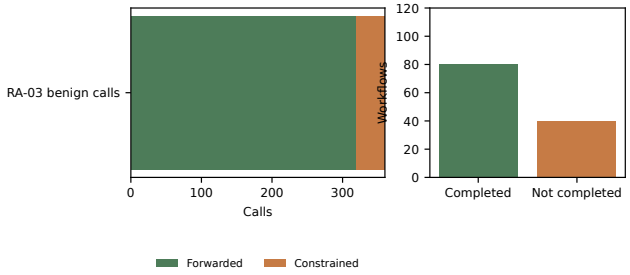


Figure 8: Measured availability cost in the selected RA-03 synthetic workload.

8.2 Valid hostile peers

Signature validation authenticates the issuer; it does not establish that the issuer's observation is true. The sealed hostile-peer burst table is computed from declared formulas, not from executed warning bursts. Its idempotence and quota-plus-monitor entries illustrate candidate receiver policies but establish no measured overload behavior. Hostile-peer behavior remains to be tested.

8.3 Security-availability trade-off

Containment-first has a material availability cost in the selected synthetic false-warning treatments. In the inside-window early and boundary treatments, 40 of 120 benign agent calls are constrained and 0 of 40 affected workflows complete. The remaining no-evidence and late treatments forward 240 of 240 benign agent calls and complete 80 of 80 workflows. The aggregate 80 of 120 result is reported for accounting, but does not blend away the treatment-specific false-warning cost.

The receiver-strategy frontier separates no restriction, continuous Standing Guard, arrival-triggered class restriction, Exact Binding, and Campaign Correlation. The latter covers declared related substitutions that Exact Binding permits; its evaluated scope remains bounded.

8.4 External-warning coverage and admission

A credential-free successor evaluates the complete sealed external ledger from the pinned AgentDojo commit [12] and pinned Prompt Guard 2 86M output configuration [25]; it consumes preserved detector outputs rather than rerunning the detector. Its declared normalizer maps `LABEL_0` to no warning and `LABEL_1` to a TCX prompt-attack category. Table 12 separates source coverage, detector output, normalization, receiver admission, and exact binding. Of 72 attack-bearing source cases, 25 produce a warning and an admitted exact binding; 47 produce no warning and therefore no actionable TCOP evidence. TCOP cannot compensate for a detector no-warning result.

Table 13 reports every policy over all 168 external source cases. Arrival Guard, Exact Binding, and Campaign Correlation block 25 of 72 harmful actions, the 25 for which accepted exact evidence exists, and forward the remaining 47 no-warning harmful actions. They forward all 96 benign no-warning actions. Standing Guard blocks 72 of 72 harmful actions but constrains all 96 of 96 benign actions because it is a standing receiver guard. This is an integration and authorization-coverage result, not an estimate of detector quality, warning prevalence, or deployment effectiveness.

Table 14 adds deliberately derived protocol controls to the selected external bases. Exact Binding and Campaign Correlation apply no restriction to partial or mismatched bindings. Stale and replayed context are rejected before policy. Sender-suggested-only relation information remains nonrestrictive under Campaign Correlation. Campaign Correlation forwards all 12 harmful substitutions without a receiver-created relation, including 8 session-lineage and 4 delegation variants; it blocks all 12 paired substitutions when the receiver has created the corresponding local relation. These controls demonstrate the declared receiver logic, not a general claim about correlation quality.

8.5 Local overhead

Appendix E separates local authorization, gateway, and warning-to-enforcement overhead for disabled and fixed-TTL caches. Correctness and causal replay disable caching.

9 Related Work

9.1 Threat-intelligence exchange

STIX/TAXII, MISP, and DShield distribute threat information [13, 28, 29, 37]. TCOP may ingest evidence derived from them; it addresses the later agent-runtime question of whether a receiver should authorize one pending tool or capability action after receipt-, session-, and action-specific validation. These systems do not specify that action-time receiver-local authorization contract.

9.2 Response orchestration

RID, DOTS, and OpenC2 exchange incident reports, mitigation signals, and defense commands [27, 34, 35]. CACAO and SOAR coordinate playbooks and response workflows

Table 11: Measured RA-03 availability cost under selected synthetic false-warning treatments and capability restriction; this is not a universal false-positive rate.

Treatment group	Attempted	Forwarded	Constrained	Workflow completion	Affected capability
Inside-window early and boundary	120	80	40	0/40	repository.write in frozen benign metadata workflow
No context, outside window, post-detection, and post-containment	240	240	0	80/80	no restriction in these treatments
All selected treatments	360	320	40	80/120(66.7%)	selected synthetic capability restriction

Table 12: Full external-warning pipeline coverage. All 168 cases in the sealed detector-output ledger are evaluated; a warning is not a detector-quality estimate.

Stage or source category	Cases
Attack-bearing source cases	72
Detector warning → normalized TCX → admitted exact binding	25/25/25
Detector no-warning → no actionable TCOP evidence	47
Benign source cases, all detector no-warning	96
Total no actionable evidence	143

[9,19]. Either can implement a response after TCX acceptance. TCOP instead bounds the preceding decision input: whether signed runtime evidence applies to one pending receiver-side agent action. Course of action, workflow execution, and enforcement remain receiver-local.

9.3 Trust, identity, and local policy

KeyNote and macaroons support delegated authorization [6, 8]; TCX instead carries behavioral runtime evidence into a locally created decision. This avoids imported evidence becoming ambient enforcement authority, related to the confused-deputy concern [15]. Zero trust separates policy decision from enforcement [36]; SPIFFE federation authenticates foreign workloads [39]; and RATS separates evidence, appraisal, verifier, and relying party [7]. TCOP applies those separations to cross-domain agent actions: it combines authenticated peer identity with receiver-local correlation and appraisal. Collaborative intrusion detection identifies relevant coordination and adversarial-participant questions [10]; the central audit here is only a bounded fact-equivalent control.

9.4 Agent interoperability and tool protocols

MCP standardizes client access to server tools and resources [26]; its gateway is the reference tool-call enforcement point here. A2A standardizes independent-agent discovery and collaboration [1], and ANP addresses agent-network communication and discovery [2]. They can supply transport or session context. Table 3 summarizes the contract-level distinction: TCOP adds receipt-bound validation of signed runtime evidence against a pending receiver-side agent action, while leaving response selection and enforcement with the receiver.

9.5 Shared Signals and agent authorization

SSF, CAEP, and RISC carry identity, credential, and session state changes between parties as Security Event Tokens [11,18,38,40]. AIMS gives best practices for agent identity, credentials, and OAuth-based authorization; its Section 11 permits Shared Signals subscriptions and recommends recipient remediation, including access attenuation or renewed policy evaluation [20]. AAP covers identity assertions, scoped grants, delegation, short-lived behavioral attestation presented with credentials, and cross-organization credential revocation pushed to federation members [14]. The Liu framework composes OAuth 2.0 extensions for delegated agent authorization at token issuance, with audit records for post-hoc review [23]. These mechanisms carry identity and session state or decide authorization at grant or token time; AIMS and AAP also include runtime signals. TCOP carries what another domain observed an agent doing, bound to a specific pending action at the receiver, where it can only tighten authority.

9.6 Agent and tool security

Prompt injection and tool-integrated agents motivate the synthetic scenarios. Liu et al. benchmark prompt-injection attacks and defenses, while InjecAgent evaluates indirect injection against tool-integrated agents [24,41]. TCOP does not compete with those detectors. It evaluates whether externally observed runtime evidence can affect a locally governed pending action in time.

10 Discussion, Limitations, and Conclusion

10.1 Why not just isolate?

In October 2026, OpenAI moved frontier-model training to no live internet access [32]; Anthropic extended its no-live-access rule to all internal evaluations while minimizing internet access for training [5]. The isolation failures that prompted those changes included a zero-day in a package registry cache proxy [31] and a misconfigured DNS resolver [32]; an allowlisted host was also the path out [21]. Isolation does not cover deployed agents. TCOP addresses the case where containment fails.

The design gives each receiver a local peer table containing per-peer scope, reliability, reachability, and delivery latency.

Table 13: Full-population receiver authorization outcomes over 72 attack-bearing and 96 benign external source cases. Arrival Guard, Exact Binding, and Campaign Correlation use accepted evidence conditionally; Standing Guard is a standing local restriction.

Policy	Harmful blocked	Harmful forwarded	Benign constrained	Benign forwarded
Local Only (C0)	0/72	72/72	0/96	96/96
Arrival Guard (C1)	25/72	47/72	0/96	96/96
Exact Binding (C2)	25/72	47/72	0/96	96/96
Campaign Correlation (C2E)	25/72	47/72	0/96	96/96
Standing Guard (C3)	72/72	0/72	96/96	0/96

Table 14: Independent Warning Admission v2 derived controls. Each row contains 12 derived cases. The substitution rows contain 8 session-lineage and 4 delegation variants.

Control	Receiver result
Partial binding	Exact Binding/Campaign Correlation: 0/12 restrictions
Mismatched binding	Exact Binding/Campaign Correlation: 0/12 restrictions
Stale or replayed context	Campaign Correlation: 12/12 rejected before policy
Sender-suggested-only relation	Campaign Correlation: 0/12 restrictions
Harmful substitution, no B-local relation	Campaign Correlation: 12/12 forwarded
Harmful substitution, B-local relation	Campaign Correlation: 12/12 blocked

These tables are never exchanged between nodes. Keeping them local is intended to avoid propagating bad peer state through shared tables, the mechanism by which BGP hijacks and route leaks spread. This peer-table design is not evaluated here.

10.2 Limitations

The claim boundary in Section 2 and Table 17 applies throughout. Evidence is limited to synthetic tools and scenarios, receipt-based correlation, one reference gateway, local-harness performance, and one frozen model/runtime selection. Post-denial branches and Campaign Correlation selectivity are bounded reference-strategy results. External-warning results consume preserved detector outputs, not estimates of detector quality, warning prevalence, or production effectiveness. Exact Binding's equal containment holds only on the accepted binding-matched subset, not the full cohort. Signed-envelope mutations establish only the exercised receiver behavior; hostile-peer and correlation tables are formula-computed, with typed-in zero correlation counters, not measured evidence. Key rotation, revocation propagation, heterogeneous federation, and cross-host transport delay remain unevaluated. The visible RA-03 eligibility correction (Table 16) affects benign availability; the separately rooted strict causal comparison excludes RA-03.

Future work: runtime bindings across hosts. A planned, pre-registered cross-host study, which has not yet run, will define abstract tightening actions once and bind them per runtime, separating native and harness-built primitives without pooling results. It will compare a bare agent (E0), the same agent in a sandbox runtime (E1), and TCOP bound to it (E2). Deny-by-default egress already blocks unknown destinations; the study is designed to test receiver-bound evidence for an allowed but misused destination. It predicts that only receiver-bound evidence will act in that case, and only if its binding takes effect before the action. A poll-delayed binding will prevent no earlier actions; the harness instant cut will test that gap. A transport binding could carry a TCX as a Security Event Token over Shared Signals [18,40]. Here CH-N denotes the cross-host amendment series in files named `spec/external-warning-adaptive-crosshost-amendment-00N.md`. See the sealed repository amendments CH-003 (`spec/external-warning-adaptive-crosshost-amendment-003.md`), CH-004 (`spec/external-warning-adaptive-crosshost-amendment-004.md`), and CH-005 (`spec/external-warning-adaptive-crosshost-amendment-005.md`).

10.3 Conclusion

TCOP makes timely cross-domain evidence an input to receiver-local authorization. The evaluated strategies expose a precision, coverage, and availability frontier rather than a mandatory protocol response. In every tested single-environment reference-path and replay condition, gateway blocks cite receiver-local policy and decision records. The artifact preserves source roots, exclusions, sealed plans, and regenerated results so each claim can be checked against its evidence.

References

[1] A2A Project. Agent2agent (a2a) protocol specification. A2A Protocol v1.0, 2026. Version 1.0.1 current at access; accessed August 2, 2026.

[2] Agent Network Protocol. Agent network protocol. Protocol overview, 2026. Overview page; accessed August 2, 2026.

[3] Anthony Albanese. Press conference - New York. https://www.pm.gov.au/media/press-conference-new-york, September 2026. Published September 24.

[4] Anthropic. Investigating three real-world incidents in our cybersecurity evaluations. https://www.anthropic.com/news/investigating-incidents-cybersecurity-evals, July 2026. Published July 30; corrected August 3.

[5] Anthropic Alignment. Investigating unintended model actions in our evaluations and internal use. https://www.anthropic.com/research/investigating-unintended-model-actions, October 2026. Published October 9.

[6] Arnar Birgisson, Joe Gibbs Politz, Úlfar Erlingsson, Ankur Taly, Michael Vrable, and Mark Lentczner. Macaroons: Cookies with contextual caveats for decentralized authorization in the cloud. In *Network and Distributed System Security Symposium*. Internet Society, 2014.

[7] Henk Birkholz, Dave Thaler, Michael Richardson, Ned Smith, and Wei Pan. Remote ATtestation procedureS (RATS) architecture. RFC 9334, Internet Engineering Task Force, 2023.

[8] Matt Blaze, Joan Feigenbaum, John Ioannidis, and Angelos D. Keromytis. The KeyNote trust-management system version 2. RFC 2704, Internet Engineering Task Force, 1999.

[9] Robert A. Bridges, Ashley E. Rice, Timothy S. Oesch, Jeffrey A. Nichols, Cory L. Watson, Kevin D. Spakes, Savannah A. Norem, Michael R. Huettel, Brian C. Jewell, Brian Weber, Connor M. Gannon, Olivia M. Bizovi, Samuel C. Hollifield, and Samantha H. Erwin. Testing SOAR tools in use. *Computers & Security*, 129:103201, 2023.

[10] Rainer Bye, Seyit Ahmet Camtepe, and Sahin Albayrak. Collaborative intrusion detection framework: Characteristics, adversarial opportunities and countermeasures. In *Workshop on Collaborative Methods for Security and Privacy*. USENIX Association, 2010.

[11] T. Cappalli and A. Tulshibagwale. OpenID Continuous Access Evaluation Profile 1.0. OpenID Foundation, https://openid.net/specs/openid-caep-1_0-final.html, August 2025.

[12] Edoardo Debenedetti, Jie Zhang, Mislav Balunović, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. Agentdojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *Advances in Neural Information Processing Systems*, 2024.

[13] Alexandre Dulaunoy and Andras Iklody. MISP core format. Internet-Draft, draft-20, November 2025. Work in progress; accessed August 2, 2026.

[14] A. Fane. OpenA2A Agent Authorization Protocol (AAP). Internet-Draft draft-fane-opena2a-aap-02, https://datatracker.ietf.org/doc/draft-fane-opena2a-aap/02/, September 2026. Individual submission, work in progress.

[15] Norman Hardy. The confused deputy: Or why capabilities might have been invented. *ACM SIGOPS Operating Systems Review*, 22(4):36–38, 1988.

[16] Vincent C. Hu, David F. Ferraiolo, Rick Kuhn, Adam Schnitzer, Kenneth Sandlin, Robert Miller, and Karen Scarfone. Guide to attribute based access control (ABAC) definition and considerations. Special Publication 800-162, National Institute of Standards and Technology, 2014.

[17] Hugging Face. Security incident disclosure — July 2026. https://huggingface.co/blog/security-incident-july-2026, July 2026. Published July 16.

[18] P. Hunt, M. Jones, W. Denniss, and M. Ansari. Security Event Token (SET). RFC 8417, https://www.rfc-editor.org/rfc/rfc8417, July 2018.

[19] Bret Jordan, Allan Thomson, Vasileios Mavroeidis, and Mateusz Zych. CACAO security playbooks version 2.0. OASIS Committee Specification 01, 2023.

[20] P. Kasselman, J. Lombardo, Y. Rosomakho, B. Campbell, N. Steele, and A. Parecki. AI Identity Management System. Internet-Draft draft-ietf-wimse-aims-00, IETF WIMSE Working Group, https://datatracker.ietf.org/doc/draft-ietf-wimse-aims/00/, September 2026. Work in progress.

[21] Paul Kassianik and Yaron Singer. Chinese Model Kimi K3 Breaks UK AI Safety Institute Benchmark Evaluations. https://blog.frontier.security/chinese-model-kimi-k3-breaks-uk-ai-safety-institute-benchmark-evaluations/, August 2026. Explicit update August 8; initial publication date not stated on inspected primary page.

[22] Hugo Larcher, Adrien Carreira, raphael g, and Christophe Rannou. Anatomy of a Frontier Lab Agent Intrusion: A Technical Timeline of the July 2026

Incident. https://huggingface.co/blog/agent-intrusion-technical-timeline, July 2026. Published July 27.

[23] D. Liu, H. Zhu, S. Krishnan, A. Parecki, and H. Xue. AI Agent Authorization Integration Framework. Internet-Draft draft-liu-ai-agent-authorization-integration-00, https://datatracker.ietf.org/doc/draft-liu-ai-agent-authorization-integration/00/, July 2026. Individual submission, work in progress.

[24] Yupei Liu, Yuqi Jia, Runpeng Geng, Jinyuan Jia, and Neil Zhenqiang Gong. Formalizing and benchmarking prompt injection attacks and defenses. In *33rd USENIX Security Symposium*. USENIX Association, 2024.

[25] Meta Llama. Llama prompt guard 2 86m model card. Hugging Face model card, 2025.

[26] Model Context Protocol. Authorization. Model Context Protocol Specification, 2025-06-18, 2025. Versioned specification URL; accessed August 2, 2026.

[27] Kathleen Moriarty. Real-time inter-network defense (RID). RFC 6545, Internet Engineering Task Force, 2012.

[28] OASIS Cyber Threat Intelligence Technical Committee. STIX version 2.1. OASIS Standard, 2021.

[29] OASIS Cyber Threat Intelligence Technical Committee. TAXII version 2.1. OASIS Standard, 2021.

[30] OpenAI. How we will do better for Australia. https://openai.com/index/how-we-will-do-better-for-australia/, September 2026. Published September 28; includes separately dated later updates.

[31] OpenAI. OpenAI and Hugging Face partner to address security incident during model evaluation. https://openai.com/index/hugging-face-model-evaluation-security-incident/, July 2026. Published July 21; includes subsequent updates.

[32] OpenAI. Securing our frontier model training environment. https://openai.com/index/securing-our-frontier-model-training-environment/, October 2026. Published October 23.

[33] OpenAI Alignment. Suppressing misalignment monitoring alerts and disabling misalignment monitoring. https://alignment.openai.com/misalignment-reports/suppressing-misalignment-monitoring-alerts-and-disabling-misalignment-monitoring/, October 2026. Posted and updated October 20; incidents and discovery October 3 and October 6.

[34] Tirumaleswar Reddy, Dan Wing, Mohamed Boucadair, and Jan Medved. Distributed denial-of-service open threat signaling (DOTS) signal channel specification. RFC 9132, Internet Engineering Task Force, 2021.

[35] Jason Romano and Duncan Sparrell. Open command and control (OpenC2) language specification version 1.0. OASIS Committee Specification Draft, 2018.

[36] Scott Rose, Oliver Borchert, Stu Mitchell, and Sean Connelly. Zero trust architecture. Special Publication 800-207, National Institute of Standards and Technology, 2020.

[37] SANS Internet Storm Center. Using DShield's data feeds. SANS Internet Storm Center documentation, 2026. Accessed August 2, 2026.

[38] M. Scurtescu, A. Backman, P. Hunt, J. Bradley, S. Bounev, and A. Tulshibagwale. OpenID RISC Profile Specification 1.0. OpenID Foundation, https://openid.net/specs/openid-risc-1_0-final.html, August 2025.

[39] SPIFFE Community. SPIFFE federation. SPIFFE Standard, 2026. Versioned specification URL; accessed August 2, 2026.

[40] A. Tulshibagwale, T. Cappalli, M. Scurtescu, A. Backman, J. Bradley, and S. Miel. OpenID Shared Signals Framework Specification 1.0. OpenID Foundation, https://openid.net/specs/openid-sharedsignals-framework-1_0-final.html, August 2025.

[41] Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. InjecAgent: Benchmarking indirect prompt injections in tool-integrated large language model agents. In *Findings of the Association for Computational Linguistics: ACL 2024*, pages 10471–10506. Association for Computational Linguistics, 2024.

A Open Science Appendix

The public artifact repository is available at https://github.com/cloudronin/tcop/tree/preprint-v1. It contains the paper source, source-verification reports, normalized data, figure and table sources, expected results, claim and number audits, a compact reviewer package, the sealed TCX Validation-Value Study v2, Post-Denial Substitution Study v1, Campaign Correlation Frontier Study v1 (artifact identifier C2E), Independent Warning Admission v2 external-stratified study, and the full-population external-warning successor. The predecessor roots remain unchanged for lineage. It contains no provider credentials, production credentials, personal paths, or unpublished incident data.

The artifact is organized around four reproduction tiers. Tier 0 verifies immutable roots, normalizes data, regenerates figures and tables, audits manuscript numbers and anonymity, and builds the paper. Tier 1 reruns the deterministic causal core without external credentials. Tier 2 strictly replays frozen agent traces through local-only and TCOP treatments without model credentials. Tier 3 is an optional credentialed regeneration of live traces and is not required for the causal findings.

The default reviewer command runs Tier 0 plus strict agent replay without reading a model-provider environment variable. The validation-value study is credential-free and includes its sealed output, pre-analysis plan, expected results, mutation corpus, and two byte-identical clean rerun report. The post-denial substitution, Campaign Correlation, and independent-warning studies include sealed plans, normalized summaries, source manifests, candidate and selection ledgers where applicable, and dedicated verifier commands documented in the public artifact repository. The expected-results manifest records the strict-pair counts, single-environment reference-path arms, control outcomes, strategy digests, source roots, validation-value results, and all study results used by the manuscript.

The artifact uses Python, the TCOP CLI, Matplotlib for vector figures, and a TeX distribution for the PDF. Docker is required only for the optional reference-gateway smoke path, which also requires a separately supplied pinned gateway checkout. The source-verification report records the formal amendment that admits the available deterministic evidence root in place of an unavailable predecessor root.

Tier 0, Tier 1, Tier 2, and the validation-value verifier complete without provider credentials. Tier 3 documents its provider/runtime lock, eligibility criteria, bounded attempts, expected variability, and cost category separately from frozen-trace reproduction. A fresh provider run is not permitted to replace the replay evidence used for the paper's causal claims.

B Ethics Appendix

All evaluated tools and target systems are synthetic. No production credentials, real repositories, customer systems, datasets, or workloads were attacked. Prompts and tool calls are restricted to a test environment, and no autonomous production enforcement occurred. The credentialed model activity was bounded by synthetic tool interfaces. No human subjects were involved, and the study does not collect or release personal data.

The work concerns defensive handling of potentially harmful tool calls. An executable gateway and replay environment could be misused if presented as a way to control another domain. The artifact reduces this risk through synthetic inputs, omitted target infrastructure and credentials, and a receiver-local authorization boundary. The evaluated protocol does not export a remote enforcement interface or a production attack path.

False or malicious warnings are the principal ethical and operational risk. The paper reports the measured benign-workflow disruption caused by containment-first restriction. The formula-computed hostile-peer burst table supplies no measured evidence of overload behavior. A receiver decides whether to restrict, monitor, deduplicate, or rate-limit a warning. This cost and responsibility remain part of the design result.

The public incident is a motivation for the cross-domain failure pattern, not an attribution or empirical reconstruction.

C Frozen Strategy Details

The study certifies four objective-specific frozen configurations: containment-first, balanced federated, utility-preserving, and forensic-oriented. The paper's primary causal deterministic comparison uses containment-first because it is the configuration with matched local-policy pairs. Balanced and utility configurations are retained in the artifact but their unmatched comparisons are excluded from the causal claim. Artifact configuration identifiers remain in the machine-readable strategy manifest.

The full manifest digests and certification status appear in the source-verification report and normalized strategy records. The paper does not portray the forensic configuration as a separable composable overlay, and it makes no unsupported reconstruction-quality claim.

D Live Amendment History

The live evaluation preserves a visible sequence of sealed artifacts. The earliest provider-failure artifacts remain negative results. Amendments correct provider transport compatibility, align frozen benign eligibility, correct an artifact completion gate, reconcile a derived utility counter from immutable replay rows, and add the reference-path origin relay without new model sampling. The immutable historical artifact identifier retains its original end-to-end label. None changes TCX fields, receiver-local policies, scenario prompts, tools, treatment definitions, or frozen traces.

D.1 RA-03 eligibility correction

Amendment 003 corrected an eligibility implementation that applied a global high-risk capability rule to the benign RA-03 metadata-write workflow. The frozen benchmark had already declared `repository.write` permitted for that workflow. The original and corrected rules, as well as their distinct retained trace-eligibility reports, are included in the artifact. Table 16 gives the sensitivity view required to distinguish a trace-eligibility correction from a changed harmful-action result.

Table 15: Live runtime amendment history. Digest prefixes identify the immutable predecessor and successor roots; full digests are retained in the normalized amendment-chain data and source-verification report. The first two predecessor artifacts are retained provider-failure negatives.

Amendment	Cause	Model sampling?	Traces?	Protocol / policy?	Result derivation?	Predecessor digest	Successor digest
001	Provider completion-token field	No successful sampling	No	No	No	e5cf49806b70	698ca3c116af
002	Provider reasoning mode	No	No	No	No	698ca3c116af	f9bccfcaeff8
003	RA-03 eligibility aligned to frozen truth	Yes, eligible cohort capture	No	No	Eligibility only	f9bccfcaeff8	cebc669a7a3c
004	Completion-gate ordering	No	No	No	No	cebc669a7a3c	24a20e9c48a2
005	Derived utility reconciliation	No	No	No	Yes, replay-row aggregation	24a20e9c48a2	2b1f92ff4481
006	End-to-end tcopd-a relay replay	No	No	No	Reference-deployment evidence	2b1f92ff4481	546f3547b727

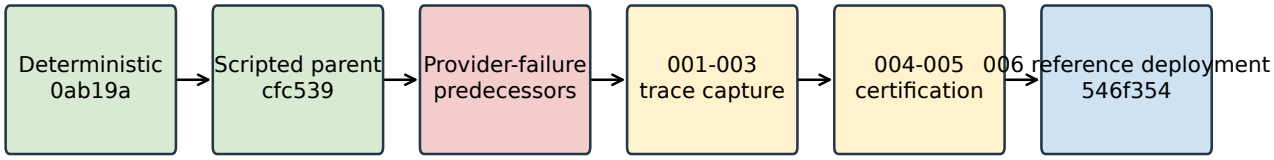


Figure 9: Artifact and amendment lineage. Short prefixes identify roots; the source-verification report records full digests and predecessor links.

Table 16: RA-03 eligibility correction. The amended rule accepts the already frozen benign metadata capability; deterministic causal counts do not use RA-03.

Rule	Attempts	Eligible
Pre-correction global rule	60	0
Amendment 003 permitted-capability rule	20	20

E Extended Results

The normalized data preserves the full strict-pair and treatment-level rows with source artifact digests, paths, and row identifiers. The timing result distinguishes delivery before the first harmful opportunity, at the first-action authorization boundary, after initial harm but before later actions, after receiver-local detection, and after partial local containment. No figure interpolates a causal effect between these measured placements.

The selected utility result is intentionally reported alongside security benefit. Restriction expiry and recovery remain receiver-local, and the artifact retains the raw treatment rows required to inspect the completion calculation.

F Failure-Control Detail

Ten executed live controls passed: invalid signature, wrong receipt, expired context, replayed context, monitor-only policy, gateway cache disabled, receiver unavailability, authorization timeout, stale decision, and arrival after local containment. Unknown peer and remote TCX action were not injected live; executed signed-envelope mutations separately cover unknown-peer rejection and ignored remote action and enforcement fields. Disallowed import type, no remote enforcement, gateway restart, and session termination before arrival were recorded as passed without execution and remain untested design properties. Appendix E preserves all source-control rows and their evidence classifications; Table 7 distinguishes the executed mutation corpus. In every evaluated gateway block, recorded provenance is Domain-B-local; the literal-zero remote-enforcement counter supplies no ex-

Table 17: What the evaluation supports and does not support.

Evidence	Supported scope
Deterministic matched pairs	Causal comparison under matched frozen local policy and synthetic scenarios
Executable replay	Exact captured action-sequence comparison without model credentials
Live trace generation	A bounded credentialed cohort generated action attempts
Single-environment reference-path deployment	A signed tcopd-A-to-tcopd-B path and receiver-local gateway decisions in one reference environment
Validation-value and assurance cohort	Semantic binding and executed receiver-validator mutations; hostile-peer and correlation tables are formula-computed illustrations
Post-denial substitution replay	Policy-conditioned post-denial branches in a bounded reference runtime, not deployment prevalence
Campaign Correlation frontier	Deterministic receiver-local Campaign Correlation selectivity, not a general escalation policy or deployment-effectiveness estimate
Full external-warning ledger	All 168 sealed external source cases: 25 accepted exact bindings, 47 attack-bearing no-warning cases, and 96 benign no-warning cases; authorization coverage, not detector-quality evidence
Not established	Production deployment, Internet-scale federation, key-lifecycle operation, uninstrumented incidents, or universal superiority to central defense

Table 18: Strict replay timing treatments. A treatment can be too late for one action while still affecting later opportunities.

Action-relative placement	Improved	Unchanged	Harmful-action delta
Before first harmful opportunity	24	20	-72
At first-action authorization boundary	24	20	-72
After initial harm, before later actions	24	20	-48
After receiver-local detection	24	20	-48
After partial local containment	12	32	-24

ecuted misuse test. The artifact's `docs/KNOWN_ISSUES.md` records the correction without changing the sealed source.

G Reproducibility Details

The default reviewer workflow avoids live credentials. It verifies source roots, regenerates all paper-local derivatives, and invokes strict replay on frozen traces. Exact expected counts and full source digests are machine-checkable in the public artifact repository manifest. The deterministic causal-core tier writes a new output root and compares its declared deterministic results; it never overwrites the sealed sources.

The live provider environment is documented only for optional trace regeneration. A current provider response can differ from the frozen cohort; such a replication does not replace the trace-replay evidence or modify the paper's claims.

Table 19: Negative and failure controls. Ten controls (NC-01–04, NC-07, NC-10–12, NC-14, NC-16) were executed and passed in the sealed live artifact. NC-05 and NC-09 are covered by executed signed-envelope mutations in `artifacts/tcx-validation-value-v2/property-test-report.json` (`issuer` and `action_semantic`, respectively), not by live injections. Four rows (NC-06, NC-08, NC-13, NC-15) were recorded as passed in the sealed live artifact without executing the condition; they are untested design properties, not results. See the artifact's known-issues file, `docs/KNOWN_ISSUES.md`.

Condition	Expected behavior	Observed behavior	Invariant	Pass	Source / evidence
Invalid signature	Reject before restriction	Rejected; no restriction	Signed input	Yes	NC-01; live executed
Wrong receipt	Reject before restriction	Rejected; no restriction	Receipt correlation	Yes	NC-02; live executed
Expired context	Reject before restriction	Rejected; no restriction	Bounded freshness	Yes	NC-03; live executed
Replayed context	Reject before restriction	Rejected; no restriction	Replay protection	Yes	NC-04; live executed
Unknown peer	Reject before restriction	identity_unknown; no restriction	Authorized peer	Yes	NC-05; mutation: issuer
Disallowed import type	Reject before restriction	Not executed; design property	Context class	Not tested	NC-06; not executed
Monitor-only policy	Do not preempt first call	First call not blocked	Local detection timing	Yes	NC-07; live executed
No remote enforcement	Never accept remote enforcement	Not executed; design property	Receiver authority	Not tested	NC-08; not executed
Remote TCX action	Never interpret remote action	Remote fields action and enforcement ignored	Receiver authority	Yes	NC-09; mutation: action_semantic
Gateway cache disabled	Evaluate each authorization	Cache disabled	Replay correctness	Yes	NC-10; live executed
tcopd B unavailable	Use B-local disposition	Local fail-closed policy	Receiver authority	Yes	NC-11; live executed
Authorization timeout	Use B-local disposition	Sender does not choose timeout	Receiver authority	Yes	NC-12; live executed
Gateway restart	Recompute local state	Not executed; design property	Receiver authority	Not tested	NC-13; not executed
Stale decision	Recompute local state	Fresh decision used	Receiver authority	Yes	NC-14; live executed
Session termination before arrival	Do not cross sessions	Not executed; design property	Session binding	Not tested	NC-15; not executed
Arrival after local containment	No reversal of completed action	Non-preventive late context	Containment window	Yes	NC-16; live executed

Table 20: Local harness performance in microseconds, with 20 samples per selection and component. Authorization uses `perf_counter_ns()` around a Python dictionary cache lookup on hits, or request construction and `evaluator.authorize()` on misses; it does not time an RPC. The enabled selection is labeled fixed 5 s TTL in the artifact, but the timed loop does not exercise expiry. Gateway timing wraps adapter construction and invocation; warning-to-enforcement sums context acceptance and gateway durations. With 20 samples, p95 and p99 are near the top order statistics. These local harness measurements are not production inter-domain latency estimates.

Selection	Samples	Authorization p95 (μs)	Gateway p95 (μs)	Warning-to-enforcement p95 (μs)	Hit rate
Disabled	20	19.75	24.584	331.624	0.0
Enabled, fixed 5 s TTL	20	0.667	27.25	328.208	0.95